<COMPANY> EPA Exercise 1: Build Guide and Day 2 Plan

Nov 10, 2026 · @Lewis Wild

Read first

Part A rebuilds your **<COMPANY>** network changes in 10 ordered steps. Part B covers the other six Exercise 1 topics for tomorrow.

Ground rules

- Do Part A on your copy tonight. Tomorrow, rebuild on the real file.
- Use made-up lab passwords. Never reuse a real one.
- Do the steps in order. Step 1 comes first so you cannot lock yourself out.
- **<angle brackets>** mean: replace with your own value.

Where each step happens

Tag	Device	How to open it
[RTR]	**<COMPANY>-rtr**	Click it, CLI tab, press Enter, type **enable**, then **configure terminal**
[SW]	core-switch	Same as the router
[S0]	Server0	Click it, Services tab (or Desktop tab for IP settings)
[CLOUD]	**<COMPANY>-care-cloud** (new, ISP side)	Click it, Services tab
[ADMIN]	admin-pc (new, VLAN 1030)	Click it, Desktop tab, Command Prompt
[LAPTOP]	Laptop0 to Laptop4	Click one, Desktop tab, Command Prompt

Before you change anything

1. On [RTR], type **show running-config** and copy the output into a text file called **before-rtr.txt**.
2. On [SW], do the same into **before-sw.txt**.
3. Save your Packet Tracer copy under a new name, with the date.

These two files are your "before" evidence for the test table in Step 9.

Step 1 [RTR]: Secure management

The router has **aaa new-model** but no users, no SSH and no secrets. The sheet asks for "secure management", so this goes first.

1. On [RTR], type each line below. Replace the **<>** values.

```
configure terminal
no ip domain-lookup
username <admin> privilege 15 secret <lab-password-1>
enable secret <lab-password-2>
service password-encryption
ip domain-name <COMPANY>.local
crypto key generate rsa modulus 2048
ip ssh version 2
aaa authentication login default local
line vty 0 4
 login authentication default
 transport input ssh
 exec-timeout 5 0
end
```

2. Wait for the key to generate. It can take a few seconds.
3. Check SSH is on: **`show ip ssh`**. You want version 2.0.
4. Note: the console now asks for the username and password too. That is expected.
5. Keep this CLI window open until Step 9 proves SSH works.

Optional, if time (each one is a talking point)

```
configure terminal
login block-for 120 attempts 3 within 60
banner motd #Authorised <COMPANY> staff only#
end
```

If Packet Tracer rejects a command, skip it and say so in your notes. It is a simulator limit, not a mistake.

Step 2 [RTR]: Give the devices VLAN an address, shut the spare port

The switch is set to 10.100.1.2 with gateway 10.100.1.1, but no router interface owns 10.100.1.1. This step fixes that.

1. On [RTR], type:

```
configure terminal
interface GigabitEthernet0/1.1001
 ip address 10.100.1.1 255.255.255.248
 ip nat inside
interface GigabitEthernet0/2
 shutdown
end
```

2. Check: **`show ip interface brief`**. You want **`Gi0/1.1001`** up with 10.100.1.1, and **`Gi0/2`** administratively down.

3. Do not expect to ping the switch yet. That works after Step 3.

Step 3 [SW]: Move management to VLAN 1001, tighten the trunk, tidy up

The switch has its management IP on VLAN 1, four SVIs that do nothing, an open trunk and live spare ports. Do these in four small parts.

Part 3a: remove the old management setup

```
configure terminal
vlan 999
 name blackhole
no interface Vlan1020
no interface Vlan1030
no interface Vlan1040
no interface Vlan1048
interface Vlan1
 no ip address
 shutdown
end
```

Vlan1 must lose its address first, or the next part is rejected as an overlap.

Part 3b: management address on VLAN 1001

```
configure terminal
interface Vlan1001
 ip address 10.100.1.2 255.255.255.248
 no shutdown
ip default-gateway 10.100.1.1
end
```

Part 3c: lock down the trunk and spare ports

```
configure terminal
interface GigabitEthernet0/1
 switchport trunk allowed vlan 1001,1010,1020,1030,1040,1048
 switchport trunk native vlan 999
interface FastEthernet0/23
 switchport mode access
 switchport access vlan 999
 shutdown
interface FastEthernet0/24
 switchport mode access
 switchport access vlan 999
 shutdown
interface GigabitEthernet0/2
 switchport mode access
 switchport access vlan 999
 shutdown
end
```

The router has no untagged subinterface, so moving the native VLAN to 999 does not break anything.

If Packet Tracer says "Bad VLAN list"

It appears to reject VLAN IDs above 1005 in the trunk allowed list, even though the VLANs exist. This is a simulator limit. Try these in order, and stop at the first that works.

1. Type **`switchport trunk allowed vlan 1001`** on **`Gi0/1`**, then **`switchport trunk allowed vlan add 1010,1020,1030,1040,1048`**.
2. If the second line is rejected, skip pruning and leave the trunk carrying all VLANs.
3. In your notes, write: "Trunk pruning is valid on real IOS, but Packet Tracer rejects extended VLAN IDs in the allowed list." Then in the write-up, name pruning as a control you would add on real hardware.
4. The other lines in Part 3c are unaffected. Run them as written.
5. In the Check list below, item 1 will then show all VLANs on the trunk. That is expected.

If **`show interfaces trunk`** lists only 1001 as active

The "allowed" line can be right while the "active" and "forwarding" lines show only VLAN 1001. Packet Tracer may treat IDs above 1005 oddly in that display. Do not trust the display. Test the traffic.

1. Do Step 5 (Server0 address) first, then on Server0 open Desktop, Command Prompt, and type **`ping 10.100.10.1`**.
2. Replies mean VLAN 1010 is forwarding, and the display is only cosmetic. Note it as a simulator quirk.
3. If there are no replies, type **`no switchport trunk allowed vlan`** on **`Gi0/1`**, wait 30 seconds, and ping again.
4. If it still fails, check Server0 is on **`Fa0/1`** to **`Fa0/4`** and that **`Gi0/1.1010`** on [RTR] is up.

Part 3d: SSH on the switch

```
configure terminal
username <admin> privilege 15 secret <lab-password-1>
enable secret <lab-password-2>
service password-encryption
ip domain-name <COMPANY>.local
crypto key generate rsa modulus 2048
ip ssh version 2
line vty 0 15
 login local
 transport input ssh
 exec-timeout 5 0
end
```

Check it

1. **`show interfaces trunk`** shows the six allowed VLANs.
2. **`show ip interface brief`** shows **`Vlan1001`** up with 10.100.1.2.
3. **`ping 10.100.1.1`**. The first reply may time out. The next four should work.
4. **`show ip ssh`** shows version 2.0.

Optional, if time: port security on the server ports

```
configure terminal
interface range FastEthernet0/1 - 4
 switchport port-security
 switchport port-security mac-address sticky
 switchport port-security violation shutdown
end
```

Do not put this on the access point ports in Step 7.

Step 4 [RTR]: Fix the NAT access list

Access list 1 decides who gets NAT. Two lines are wrong: **`10.10.0.0/16`** is a stray, and **`10.100.10.0 0.0.0.15`** covers only 16 addresses of your /24 servers subnet.

1. On [RTR], type **`show access-lists`**.
2. Find the sequence numbers (10, 20, 30 and so on) for the two wrong lines.
3. Type the commands below, using your own sequence numbers in place of **`10`** and **`30`**.

```
configure terminal
ip access-list standard 1
 no 10
 no 30
 25 permit 10.100.10.0 0.0.0.255
end
```

4. Type **`show access-lists`** again. You should see six permit lines, with servers as **`10.100.10.0 0.0.0.255`**.

If Packet Tracer rejects the edit

```
configure terminal
no access-list 1
access-list 1 permit 10.100.1.0 0.0.0.7
access-list 1 permit 10.100.10.0 0.0.0.255
access-list 1 permit 10.100.20.0 0.0.0.31
access-list 1 permit 10.100.30.0 0.0.0.31
access-list 1 permit 10.100.40.0 0.0.3.255
access-list 1 permit 10.100.48.0 0.0.3.255
end
```

The fallback briefly removes NAT for everyone. That is fine on a copy.

Step 5 [S0]: DNS and DHCP on Server0

Server0 (10.100.10.2) hands out addresses to every user VLAN through the router's DHCP relay, and it will be your DNS server. The ACLs come last (Step 8), so that you can take "before" results first.

5a: Check Server0's own address

1. Click Server0, then the Desktop tab, then IP Configuration.
2. Set it to Static.
3. IP address **`10.100.10.2`**, mask **`255.255.255.0`**, gateway **`10.100.10.1`**, DNS server **`10.100.10.2`**.
4. Check it is cabled to one of **`Fa0/1`** to **`Fa0/4`** on the switch.

5b: Add the DNS record

1. Services tab, then DNS. Set the service to On.
2. Name: **`care.<COMPANY>.co.uk`**. Type: A Record. Address: **`172.16.0.50`**.
3. Click Add, then Save.

5c: Build the DHCP pools

1. Services tab, then DHCP. Set the service to On.
2. Packet Tracer will not let you remove **`serverPool`** (the Remove button is greyed out). Edit it into a small spare pool instead: gateway **`10.100.10.1`**, DNS **`10.100.10.2`**, start **`10.100.10.250`**, mask **`255.255.255.0`**, max users **`4`**. Nobody on the servers VLAN asks for DHCP, so it stays unused.
3. For each row, fill the fields and click Add (or Save if editing).

Pool name	Default gateway	DNS server	Start IP	Subnet mask	Max users
vlan1020-IT	10.100.20.1	10.100.10.2	10.100.20.10	255.255.255.224	20
vlan1030-mgmt	10.100.30.1	10.100.10.2	10.100.30.10	255.255.255.224	20
vlan1040-mobile	10.100.40.1	10.100.10.2	10.100.40.10	255.255.252.0	200
vlan1048-laptop	10.100.48.1	10.100.10.2	10.100.48.10	255.255.252.0	200

Each start IP must sit inside its own subnet. That is how the server picks the right pool for each relayed request.

For your write-up

- Server0 holds DNS and DHCP, so it is a high-value target. Only the servers VLAN should reach it, and an ACL on VLAN 1010 would be the next control.
- Packet Tracer's DNS cannot forward queries. It only answers names you add. Call that a simulator limit.

Step 6 [CLOUD]: Add the cloud care system on the ISP side

This is the second side of your trust boundary: **<COMPANY>**'s own network, then the internet, then the supplier's cloud system.

6a: Place and cable it

1. Drag a Server-PT onto the ISP side. Rename it **<COMPANY>-care-cloud**.
2. Connect it to a free port on the ISP Core switch with a copper straight-through cable.
3. Wait for the link light to go green.

6b: Give it an address

1. Click it, then Desktop, then IP Configuration. Choose Static.
2. IP **172.16.0.50**, mask **255.255.255.0**, gateway **172.16.0.1**. Leave DNS blank.
3. Check the ISP DHCP/web server does not already use **172.16.0.50**. If it does, pick another address, and change it in Step 5b and Step 8.

6c: Turn on HTTPS only

1. Services tab, then HTTP.
2. Set HTTP to Off and HTTPS to On.
3. Click **index.html** edit, and replace the page with something recognisable, such as **<html><body><h1><COMPANY> Care Management System (simulated cloud)</h1></body></html>**.
4. Save.

6d: Check it works

1. On [RTR], type **ping 172.16.0.50**. You want replies. This proves NAT and the ISP route work.
2. On the ISP DHCP/web server, open Desktop, then Web Browser, and go to **https://172.16.0.50**. You want your page.

For your write-up

Packet Tracer's HTTPS is simulated. It shows a service on port 443, not real certificates or TLS checks. Say so, and use the XAMPP and Wireshark work in Part B for real TLS evidence.

Step 7: Admin PC, two access points, wireless clients, baseline tests

This step adds the devices you need to test, then takes your "before" results while nothing is blocked yet.

7a: Admin PC on the management VLAN

1. Drag a PC onto the **<COMPANY>** side. Rename it **admin-pc**.
2. Cable it to **Fa0/9** on core-switch (VLAN 1030).
3. Click it, Desktop, IP Configuration, choose DHCP.
4. You want an address in **10.100.30.x** with gateway **10.100.30.1**.

7b: Two access points

As far as I know, Packet Tracer's AccessPoint-PT has one SSID and no VLAN tagging, so one AP cannot serve two VLANs. Check this in your version. If it cannot, use two.

1. Add two AccessPoint-PT devices (Network Devices, Wireless Devices).
2. Rename them **ap-mobile** and **ap-laptop**.
3. Cable **ap-mobile** to **Fa0/12** (VLAN 1040) and **ap-laptop** to **Fa0/16** (VLAN 1048).
4. Click **ap-mobile**, Config tab, Port 1. SSID **<COMPANY>-mobile**. Authentication WPA2-PSK. Pass phrase **<lab-key-A>**. Channel 1.
5. Click **ap-laptop**, Config tab, Port 1. SSID **<COMPANY>-laptop**. Authentication WPA2-PSK. Pass phrase **<lab-key-B>**. Channel 6.
6. Keep each key different. Do not reuse a real Wi-Fi password.

7c: Make two laptops wireless

Laptop-PT ships with a wired card. Do Laptop0 and Laptop1 first. Do the rest only if you have time.

1. Click the laptop, Physical tab, and switch it off.
2. Drag the wired module out. Drag the wireless card (WPC300N) in.
3. Switch it on.
4. Config tab, Wireless0. SSID **<COMPANY>-laptop**. Authentication WPA2-PSK. Pass phrase **<lab-key-B>**.
5. Desktop, IP Configuration, choose DHCP.
6. Move the laptop close to **ap-laptop** if it does not connect.

7d: Put one phone on office Wi-Fi

1. Click Smartphone0, Config tab.
2. Turn off the cellular connection and set the Wi-Fi: SSID **<COMPANY>-mobile**, WPA2-PSK, **<lab-key-A>**, DHCP.
3. Leave the other four phones on cellular. They are your "out in the community" staff.
4. Check this in your version. If a phone cannot use both, say so in your notes.

7e: Baseline tests, before any ACLs

On Laptop0, open Desktop, then Command Prompt. Record each result in the "Before" column of the test table in Step 9.

1. **`ipconfig /all`**. Expect **`10.100.48.x`**, DNS **`10.100.10.2`**.
2. **`nslookup care.<COMPANY>.co.uk`**. Expect **`172.16.0.50`**.
3. Web Browser, **`https://care.<COMPANY>.co.uk`**. Expect your page.
4. **`ping 10.100.1.2`**. This will succeed. That is the problem Step 8 fixes.
5. **`ssh -l <admin> 10.100.1.2`**. This will also be reachable. Also the problem.

Step 8 [RTR]: Access lists

Right now every VLAN can reach every other, including the switch. These three lists fix that. Apply them one at a time, and test after each.

8a: Clinical VLANs may only do DHCP, DNS and HTTPS to the care system

1. On [RTR], type:

```
configure terminal
ip access-list extended CLINICAL-IN
 permit udp any eq bootpc any eq bootps
 permit udp any host 10.100.10.2 eq 53
 permit tcp any host 172.16.0.50 eq 443
 deny ip any any log
interface GigabitEthernet0/1.1048
 ip access-group CLINICAL-IN in
interface GigabitEthernet0/1.1040
 ip access-group CLINICAL-IN in
end
```

2. The DHCP line is first on purpose. Without it, clients stop getting addresses.
3. On Laptop0, run **`ipconfig /release`** then **`ipconfig /renew`**. You should still get an address.
4. Open **`https://care.<COMPANY>.co.uk`**. You should still get the page.
5. Run **`ping 10.100.1.2`**. It should now fail.

8b: Only the admin VLAN may reach the devices VLAN

```
configure terminal
ip access-list extended MGMT-PROTECT
 permit tcp 10.100.30.0 0.0.0.31 10.100.1.0 0.0.0.7 eq 22
 permit icmp 10.100.30.0 0.0.0.31 10.100.1.0 0.0.0.7 echo
 deny ip any any log
interface GigabitEthernet0/1.1001
 ip access-group MGMT-PROTECT out
end
```

This filters traffic on its way to the switch. Test: from **`admin-pc`**, **`ssh -l <admin> 10.100.1.2`** should work.

8c: Only the admin VLAN may SSH to the router itself

Do this last, and only after the admin-pc SSH test passes.

```
configure terminal
ip access-list standard MGMT-VTY
 permit 10.100.30.0 0.0.0.31
 deny any log
line vty 0 4
 access-class MGMT-VTY in
end
```

Check

1. **`show access-lists`** shows your three new lists.
2. **`show ip interface GigabitEthernet0/1.1048`** says the inbound list is CLINICAL-IN.
3. After your tests, the **`deny`** lines show match counts. Screenshot them for evidence.

For your write-up

- The IT (1020) and servers (1010) VLANs have no ACL yet. Name that as a residual risk, or copy the pattern if you have time.
- A numbered list is in use for NAT only. The rest use named lists, which are easier to edit and explain.
- If something breaks, record the symptom, the cause and the fix. That is your "troubleshoot" evidence, and it must be a real problem you hit.

Step 9: Test table

The sheet asks you to test against the stated requirements, including permitted and denied traffic, and record the results. Type straight into this table as you go.

1. Run each test from the device named in the third column.
2. Fill "Before" from your Step 7e results, where you have one.
3. Fill "After" once Step 8 is done.
4. Mark pass if "After" matches "Expected".
5. Screenshot each result. Name the file with the test number.

#	Test	Run from	Expected after ACLs	Before	After	Pass?
1	**`ipconfig /all`**	Laptop0	10.100.48.x, gateway .1, DNS 10.100.10.2			
2	**`nslookup care.<COMPANY>.co.uk`**	Laptop0	172.16.0.50			
3	Browser to **`https://care.<COMPANY>.co.uk`**	Laptop0	Page loads			

#	Test	Run from	Expected after ACLs	Before	After	Pass?
4	**`ping 172.16.0.50`**	Laptop0	Denied (only 443 is allowed)			
5	**`ping 10.100.10.2`**	Laptop0	Denied			
6	**`ping 10.100.1.2`**	Laptop0	Denied			
7	**`ssh -l <admin> 10.100.1.2`**	Laptop0	Denied			
8	**`ssh -l <admin> 10.100.48.1`**	Laptop0	Denied (after 8c)			
9	**`ssh -l <admin> 10.100.1.2`**	admin-pc	Login prompt, then success			
10	**`ssh -l <admin> 10.100.30.1`**	admin-pc	Login prompt, then success			
11	**`telnet 10.100.1.1`**	admin-pc	Refused (SSH only)			
12	DHCP address and HTTPS page	Smartphone0 (Wi-Fi)	10.100.40.x, page loads			
13	**`show ip nat translations`**	[RTR]	Entries for client addresses			
14	**`show access-lists`**	[RTR]	Match counts on the deny lines			

Notes

- Test 10 uses **`10.100.30.1`**, the router address on the admin VLAN. Check it with **`show ip interface brief`** if it fails.
- Packet Tracer's output for a blocked ping varies. "Request timed out" and "Destination host unreachable" both count as denied.
- If a test fails and you fix it, add one line below the table: what failed, why, what you changed, and the retest result.

Step 10: Save, capture evidence, record the design

10a: Save the running configs

1. On [RTR], type **`copy running-config startup-config`** and press Enter to confirm.
2. On [SW], do the same.
3. Save the Packet Tracer file.

10b: Capture the "after" evidence

Save each output into a text file, or screenshot it.

Device	Commands	File name
[RTR]	**`show running-config`**	after-rtr.txt
[RTR]	**`show ip interface brief`**, **`show ip route`**, **`show ip ssh`**, **`show access-lists`**, **`show ip nat translations`**	rtr-checks.txt
[SW]	**`show running-config`**	after-sw.txt
[SW]	**`show vlan brief`**, **`show interfaces trunk`**, **`show ip interface brief`**	sw-checks.txt
[S0]	Screenshot of the DNS record and the four DHCP pools	server0.png
[CLOUD]	Screenshot of the Services tab with HTTPS on and HTTP off	cloud.png

10c: Record the design

The sheet asks for a logical design showing segmentation, routing and security zones. This table is the core of it. Add it to your diagram.

VLAN	Name	Subnet	Gateway	Purpose and zone
1001	routers	10.100.1.0/29	10.100.1.1	Network devices and management interfaces
1010	servers	10.100.10.0/24	10.100.10.1	Server0: DNS and DHCP
1020	IT	10.100.20.0/27	10.100.20.1	IT staff
1030	management	10.100.30.0/27	10.100.30.1	Admin workstations, the only SSH source
1040	clinical-mobile	10.100.40.0/22	10.100.40.1	Phones on office Wi-Fi
1048	clinical-laptop	10.100.48.0/22	10.100.48.1	Laptops on office Wi-Fi
999	blackhole	none	none	Unused ports and trunk native VLAN
ISP link	n/a	203.0.113.0/30	.1 ISP, .2 **`<COMPANY>`**	Outside the trust boundary
ISP LAN	n/a	172.16.0.0/24	172.16.0.1	Cloud care system at 172.16.0.50

Mark three trust boundaries on your diagram: **<COMPANY>** LAN, the internet, and the cloud care system. Show community staff on cellular crossing the internet directly, never touching the LAN.

Part A is done when

- [ ] Steps 1 to 8 are applied and saved on both devices
- [ ] All 14 test rows have a result
- [ ] Before and after config files are saved
- [ ] The design table and diagram are done
- [ ] You have written down every real fault you hit and how you fixed it

Part B: the other six topics

The sheet lists eight highlighted topics for Exercise 1. Part A covers topic 1 (networks) and the network half of topic 5 (security technology). Part B covers the rest, using one story so the pieces connect.

The story: <COMPANY> staff write visit notes offline, cache them on laptops and phones, and sync later through an API. That gives you a prototype (topics 2 and 4), a device to harden (topic 3), data to encrypt (topic 5), a risk to analyse (topic 6), an architecture (topic 7) and policies (topic 8).

Time boxes

Day 2 is 6 hours. These boxes add up to 5 hours 25 minutes. With 10 minutes of setup and two 10-minute breaks, that fills the day. The minutes inside each part below describe the full version, so use the cut list in the running order if you fall behind.

#	Sheet topic	What you produce	Tool	Minutes
1	Design, build, test and troubleshoot networks	Part A, plus the design table and diagram	Packet Tracer	60
2	Build, test and debug a digital system to a specification	Spec, working sync endpoint, expected vs actual tests	XAMPP (Apache, PHP, MySQL)	55
4	Construct software to interact with the real world and analyse for exploits	Attack tests and fixes on the same prototype	Burp Suite, SQLMap	20
3	Configure an OS to a security policy	Hardened Windows build, before and after evidence	Windows VM, Security Compliance Toolkit	40
5	Security technology and key management (second half)	TLS on the prototype, key lifecycle table	OpenSSL, Wireshark	25

#	Sheet topic	What you produce	Tool	Minutes
6	Design and evaluate a system to a security case	One-page case, risk table, trade-offs	This doc or Word	25
7	Architect, analyse and justify a secure system	Architecture diagram, attack paths, decisions	draw.io or Packet Tracer	25
8	Develop and apply information security policy	Short policies, requirement to evidence map	This doc or Word	25
	Written justification	1,000 words (plus or minus 100)	Word	50

Topics 2 and 4: one prototype for both

If PHP gives you trouble for more than 20 minutes, switch to whichever language you know best that the room has. The sheet lists XAMPP, but it does not require it.

2a: Write the specification first (15 min)

1. Make a table with five rows: Inputs, Outputs, Functions, Security requirements, Constraints.
2. Inputs: a JSON visit note with **`client_id`**, **`staff_id`**, **`patient_ref`**, **`note_text`**, **`created_at`**, and an API token in a header.
3. Outputs: 201 created, 200 duplicate, 400 invalid, 401 not authenticated, 403 not authorised, 405 wrong method.
4. Functions: validate, authenticate, authorise, store once, acknowledge.
5. Security requirements: token required, token scope checked, parameterised SQL, no stack traces or SQL in errors, no note text in logs, HTTPS only.
6. Constraints: sync must be safe to repeat, because mobile connections drop part way.

2b: Build version 1 (30 min)

1. Start Apache and MySQL in XAMPP.
2. Create a database **`<COMPANY>`**. Make a **`notes`** table with a unique **`client_id`**, and an **`api_tokens`** table that stores a hash of each token, never the token.
3. Write one endpoint, **`sync.php`**, that reads the JSON body and does the five functions above.
4. Write it the way you naturally would. Whatever you find in testing is your real finding.
5. A ready-made version 1 is in the repo folder **`ex1-design/prototype/`** (**`sync.php`**, **`schema.sql`**, **`make_token.php`**, **`test_sync.sh`**). If you use it, read the appendix "**`sync.php`** explained" first, and be ready to explain every line. It has not yet been attacked with Burp or SQLMap, so any finding there is yours to record.

2c: Test against the specification (15 min)

#	Test	Expected	Actual	Pass?
1	Valid note with valid token	201		
2	Same note sent again	200, no second row		
3	No token	401		
4	Wrong or expired token	401		
5	Valid token without the write scope	403		
6	Empty **`note_text`**	400		
7	Invalid JSON	400, no stack trace		
8	**`GET`** instead of **`POST`**	405		
9	Very large **`note_text`**	400 or 413		
10	**`patient_ref`** set to **`' OR 1=1 --`**	Stored as text or rejected, no SQL error		

4a: Attack your own prototype (30 min)

Only test your own system on your own machine. Write down that you have authority to do so, because that is part of the "legal and ethical" marking in Exercise 2.

1. Send your tests through Burp Suite, and use Repeater to edit fields by hand.
2. Run SQLMap against the endpoint, with your token in the header option.
3. Try an oversized body, a missing field, a wrong type (a number for text), and a repeated request sent twice at once.
4. For each finding, write: what you sent, what happened, why it matters, how you fixed it.
5. Fix it, then re-run the same test. Check the other tests still pass. The sheet asks you to show the fix did not introduce new problems.
6. If you find nothing, say so, and list what you tried. Do not invent a flaw.

Part B: operating system and key management

Topic 3: Configure an OS to a security policy (45 min)

3a: Choose and snapshot (5 min)

1. Choose: a Windows 11 clinical laptop, standard user, used offline in the community. If the room only offers another OS, pick the nearest and say why.
2. Take a VM snapshot before you change anything, so you can roll back.

3b: Capture the "before" state (10 min)

Run these in PowerShell and save the output to a text file.

```
Get-NetFirewallProfile | Select Name,Enabled,DefaultInboundAction
manage-bde -status
net accounts
Get-MpComputerStatus | Select AntivirusEnabled,RealTimeProtectionEnabled
Get-Service | Where Status -eq Running
auditpol /get /category:*
```

3c: Write the threat-to-setting table (10 min)

Threat	Setting	How you check it
Lost or stolen laptop	Full-disk encryption with a PIN or equivalent, recovery key kept away from the device	**`manage-bde -status`**
Another user reads cached notes	Standard user for daily work, separate admin account, screen lock after 5 minutes	**`net user`**, lock policy
Password guessing	Minimum length and account lockout	**`net accounts`**
Malware	Defender on, tamper protection, removable drives controlled	**`Get-MpComputerStatus`**
Unpatched flaws	Automatic updates on	Windows Update history
Avoidable attack paths	SMBv1 and Remote Registry off, RDP and shares reviewed	**`Get-Service`**, optional features list
No trail after an incident	Audit logon and process creation, larger event log	**`auditpol /get /category:*`**
Network attack on the device	Host firewall on in every profile, inbound blocked by default	**`Get-NetFirewallProfile`**

3d: Apply it (10 min)

1. Use the matching baseline from the Microsoft Security Compliance Toolkit. Its LGPO tool applies it to local policy, and its Policy Analyzer compares settings.
2. Or set each row by hand. Either is fine if you can explain it.
3. Do not apply a baseline blind. Pick one setting you kept or relaxed, and explain the usability trade-off.
4. If the VM has no TPM, BitLocker needs a policy change to allow it. Record that as a lab limit.
5. If there is no baseline for your exact Windows build, use the nearest and say so.

3e: Test and show evidence (10 min)

1. Re-run the 3b commands. Save as the "after" file.
2. In Policy Analyzer, use Compare to Effective State, and screenshot the result.
3. Test three things that should fail: a standard user installing software, repeated wrong passwords, an inbound connection to a closed port.

4. Record expected against actual for each.
5. If the room gives you Windows Server instead, the Best Practice Analyzer is on the sheet's software list.

Topic 5, second half: key management (30 min)

Part A covered firewalls, ACLs and SSH. This adds encryption and the key lifecycle the sheet asks for.

5a: Decide what needs encrypting (5 min)

Data	State	Protection	Key
Visit notes cached on a device	At rest	Disk encryption	BitLocker key
Visit notes during sync	In transit	TLS 1.2 or later	Server private key
Admin access to network devices	In transit	SSH version 2	RSA host key from Part A
Office Wi-Fi	In transit	WPA2	Pre-shared key
API tokens in the database	At rest	Store a hash only	None to manage

5b: Show the difference TLS makes (15 min)

1. In Wireshark, capture on the loopback adapter. Send a note over plain HTTP. Screenshot the readable body. This is your "before".
2. Make a lab certificate:

```
openssl req -x509 -newkey rsa:2048 -nodes -keyout <COMPANY>.key -out <COMPANY
>.crt -days 365 -subj "/CN=care.<COMPANY>.co.uk"
```

3. In XAMPP, point Apache's SSL config (**`httpd-ssl.conf`**) at the two files with **`SSLCertificateFile`** and **`SSLCertificateKeyFile`**. Restart Apache.
4. Check with a browser, and with **`openssl s_client -connect localhost:443`**.
5. Capture the same request over HTTPS. Screenshot the unreadable body. This is your "after".
6. Make **`sync.php`** refuse requests that did not arrive over HTTPS. Retest.
7. Say in your write-up that the certificate is self-signed for the lab, and production would use a certificate from a trusted authority.

5c: Fill the key lifecycle table (10 min)

Key or credential	Generated	Stored	Who can access	Rotated	Revoked	Protected by
TLS server private key						
API token						
BitLocker recovery key						

Key or credential	Generated	Stored	Who can access	Rotated	Revoked	Protected by
SSH host keys (router, switch)						
Admin passwords and enable secret						
Wi-Fi pre-shared keys						

The sheet names six stages: generation, storage, access, rotation, revocation and protection. Every cell should have an answer, even if the answer is "not yet, and here is the gap".

5d: Prove revocation works

1. Delete or expire one row in **`api_tokens`**.
2. Send the same request again. Expect 401.
3. Screenshot both results.

Part B: security case and architecture

Topic 6: Design and evaluate to a security case (30 min)

Pick one problem. Lost or stolen devices holding cached visit notes fits your brief's risks, and it links to every other topic.

6a: Define the case (10 min)

Answer each in one or two lines, in your own words. The examples are prompts to adapt.

1. What needs protecting? Cached visit notes and sign-in details on about 420 staff devices.
2. From whom? Opportunistic finders or thieves, someone holding an unlocked device, and malware.
3. Why? It is health information about vulnerable people, and **`<COMPANY>`** has legal duties (topic 8).
4. What if it is compromised? Harm or distress to clients, a report to the regulator, and loss of trust.

6b: Build the risk table (10 min)

The first four columns come from your brief's risk list. Score likelihood and impact from 1 to 5 yourself, multiply for the score, and write the residual risk after the control.

Asset	Threat	Vulnerability	Control	Likelihood	Impact	Score	Residual
Cached notes on a lost device	Theft or loss	Data readable if unencrypted or unlocked	Disk encryption, PIN, remote wipe, auto-wipe after N days offline				
Cached records on any device	Another person or malware reads the cache	Large, long-lived cache	Cache only the day's caseload, clear after confirmed sync				
Care system API	Stolen or guessable token	Weak authorisation	Short-lived scoped tokens, per-user checks, rate limits				
Sync traffic	Interception, tampering, replay	Insecure synchronisation	TLS, unique note IDs, integrity checks				
Staff accounts	Misuse or compromise	Excessive permissions	Role-based least privilege, regular access review				
Monitoring	A real attack is missed	Alert fatigue	Few high-value alerts, tiered triage (feeds Exercise 3)				

6c: Evaluate the balance (10 min)

The sheet asks you to weigh security against usability, performance, cost and availability. Your poor-signal problem creates real tensions. Check these against your own judgement.

Control	Security gain	Cost to staff	Availability effect	Verdict
Remote wipe	Strong	None	Needs signal, so it cannot reach an offline device	Keep, and add auto-wipe after N days without sync
Short token life	Strong	More sign-ins	Notes written after expiry cannot sync	Allow offline entry, require a valid token to sync
Small cache	Medium	Fewer records offline	A dead zone may lack a needed record	Cache the day's visits only
MFA at sign-in	Strong	Extra step	Some methods need signal	Use an offline-capable unlock, and MFA at sync

Finish with three residual risks and what extra control or monitoring each needs. One example: a device lost inside the offline window, before any wipe can arrive.

Topic 7: Architect, analyse and justify (30 min)

7a: Draw the architecture (15 min)

One page, in draw.io or the Packet Tracer drawing tools.

1. Draw these boxes: staff devices, identity provider with MFA, device management, API gateway, care management platform, appointment system, log collector, and the **<COMPANY>** office network from Part A.
2. Draw three trust boundaries: the device, the internet and supplier cloud, and the **<COMPANY>** LAN.
3. Number the data flows 1 to 6. Label each with its control, such as TLS or scoped token.
4. Show community staff reaching the cloud directly, not through the office LAN.

7b: Apply the principles (5 min)

Principle	Where you applied it
Least privilege	
Defence in depth	
Separation of duties	
Secure by design	
Minimise attack surface	

7c: Walk the attacker's path (5 min)

Path	Countermeasure	Evidence in your work
Stolen device, then cached notes	Encryption, lock, wipe	Topic 3 after file
Phished sign-in, then API	MFA, scoped tokens	Sync tests 3 to 5
Compromised laptop on office Wi-Fi, then the servers	VLANs and ACLs	Part A tests 4 to 8
Stolen API token	Short life, revocation	Topic 5, part 5d

7d: Justify the big decisions (5 min)

For each, write the business need, the risk it addresses, and one alternative you rejected and why.

1. Device encryption with remote wipe.
2. VLAN segmentation on the office network.
3. An API with scoped tokens and offline-safe sync.

Then name the single points of failure in your Part A topology (one router, one switch, one uplink), and say what you would add for resilience.

Part B: policy and legal requirements

Topic 8: Develop and apply information security policy (30 min)

The sheet wants you to find the legal requirements, write policies, turn rules into controls, and show how compliance would be evidenced. Quote the regulator's own guidance in your write-up, not summaries. Sources are at the end of this doc.

8a: List the requirements (10 min)

Requirement	What it means for <COMPANY>	Where it shows up in your work
UK GDPR and Data Protection Act 2018	**<COMPANY>** is the data controller for client and staff data. Health data is special category data. Security of processing is required.	Encryption, access control, logging (topics 3 and 5)
Personal data breach reporting	A breach likely to risk people's rights and freedoms must be reported to the ICO without undue delay and, where feasible, within 72 hours of becoming aware. Every breach must be recorded.	Incident policy, lost-device case (topic 6)
Caldicott Principles	Eight principles, as revised in 2020, for confidential health and social care information, such as using the minimum necessary and limiting access to those who need it.	Small cache, role-based access
Data Security and Protection Toolkit	A legal requirement if **<COMPANY>** has NHS-funded services, such as continuing healthcare. Strongly recommended for other adult social care in England. The case study does not say which applies, so state your assumption.	Policy-to-evidence map (8c)
Computer Misuse Act 1990	Unauthorised access to computers is an offence, so testing needs written authorisation and a defined scope.	Topic 4, part 4a, and Exercise 2
Supplier contracts	The care platform and appointment system suppliers process data for **<COMPANY>**, so contracts need security and incident-notification terms.	Third-party policy

8b: Write four short policies (15 min)

Half a page each. Each needs a purpose, a scope, five to eight rules, an owner and a review date. The prompts below say what each should cover. The specific values are yours to choose.

1. **Access control and credentials:** unique accounts, MFA, least privilege, separate admin accounts, joiner and leaver handling, password rules, how often access is reviewed.
2. **Mobile devices and offline data:** encryption required, how fast a lost device must be reported, how much may be cached, no personal cloud copies, remote and automatic

wipe.

3. **Incident and breach management:** who to tell, how fast, the 72-hour clock, supplier contact, what is recorded.
4. **Third-party and API access:** what contracts must say, token scopes and lifetime, offboarding a supplier, incident notification by the supplier.

8c: Map each rule to a control and its evidence (5 min)

This table shows how compliance could be demonstrated, which the sheet asks for. Extend it to every policy rule.

Policy rule	Control	Evidence	Gap or exception
Only the admin VLAN may manage network devices	MGMT-VTY and MGMT-PROTECT ACLs, SSH only	Test table rows 7 to 11	IT and servers VLANs have no ACL
Devices must be encrypted	Disk encryption	**`manage-bde -status`** after file	
Sync must use encrypted transport	TLS, plain HTTP refused	Wireshark before and after	Self-signed lab certificate
API access needs a valid scoped token	Token and scope check	Sync tests 3 to 5	
Lost devices are reported at once	Incident policy	The policy document	Not yet exercised (Exercise 3)

8d: Name the gaps

List at least three honest gaps, exceptions or residual compliance risks. The sheet explicitly asks for them, and a candid list reads better than a claim that everything is covered.

Part B: the 1,000-word justification

The sheet asks for a written justification of your approach: 1,000 words, plus or minus 100, so 900 to 1,100. Write it last, once your evidence exists. Give it 50 minutes.

Word budget

Section	Words	What it must say
Context and the problem you chose	100	**`<COMPANY>`**, the offline sync change, the lost-device case
Network design and why	200	Segmentation, ACLs, management access, and what you rejected
Prototype, testing and findings	150	Spec, tests, one real finding and its fix

Section	Words	What it must say
OS hardening and key management	150	Threat to setting, key lifecycle, trade-offs
Security case, architecture and trade-offs	150	Risks, trust boundaries, balance with usability
Policy and legal	100	Duties that apply, how you would evidence them
Limits and residual risk	100	Simulator limits, gaps, next steps
Total	**950**	Leaves room to land inside 900 to 1,100

How to write it

1. Write in the first person. Say what you chose and why.
2. Give each decision a reason that points back to the brief, such as "because staff enter notes with poor signal".
3. Name one thing you considered and rejected, and why.
4. Say plainly what the simulator cannot show: HTTPS in Packet Tracer is simulated, its DNS cannot forward, and the lab certificate is self-signed.
5. Refer to your evidence by name, such as "test table row 7", so a marker can find it.
6. Check the count in Word under Review, then Word Count.

Part B: running order for Day 2

The sheet says every highlighted topic must be attempted. So aim for a basic attempt with some evidence on all eight first, then improve where time allows.

Tonight

- [ ] Do Part A on your copy only. Do not submit that file.
- [ ] Read Part B once. Work on copies out of hours is allowed, but never submit those copies.
- [ ] Charge your laptop and check you have the tools the sheet lists.

Order for Day 2

Order	Task	Minutes	Done when
1	Read the pass, merit and distinction tables. Write the eight topics as a checklist.	10	You know what each topic needs
2	Rebuild Part A on the real file, then run the test table	60	Test table has results
3	Prototype and attack tests (topics 2 and 4)	75	Spec, tests and one fix recorded
	Break	10	

Order	Task	Minutes	Done when
4	OS hardening (topic 3)	40	Before and after files saved
5	TLS and key lifecycle (topic 5)	25	Two captures and the filled table
6	Security case (topic 6)	25	Risk table scored
7	Architecture diagram (topic 7)	25	Diagram, paths and decisions
8	Policy and legal (topic 8)	25	Policies and the evidence map
	Break	10	
9	Written justification	50	Count is 900 to 1,100

If you fall behind, cut in this order

1. Optional extras in Part A: the login block, the banner and port security.
2. Test rows 8 and 9 in 2c, and any attack in 4a beyond Burp Repeater and one SQLMap run.
3. Write two policies in full and outline the other two.
4. Shorten 3b to the firewall, encryption and account commands.
5. Never cut: some evidence for every one of the eight topics, and the justification.

Rules for yourself

1. If a task runs 15 minutes over its box, stop and move on. Come back at the end.
2. After each task, take the evidence screenshot straight away.
3. Take a ten-minute break between tasks 3 and 4, and again before task 9.
4. Do not add to the network after task 2 unless a test fails.

Appendix: `sync.php` explained

You do not need to know PHP well. Read this once, then open **`sync.php`** beside it.

PHP basics you need

- PHP code sits between **`<?php`** and the end of the file. Everything runs top to bottom on each request.
- **`$name`** is a variable. **`$d['note_text']`** is the item called **`note_text`** in the array **`$d`**.
- **`[...]`** is a list or a lookup table (an array). **`=>`** pairs a name with a value.
- **`;`** ends a statement. **`//`** starts a comment.
- **`function name(...) { ... }`** defines a reusable block. **`const X = 5;`** defines a fixed value.

- **`if (...) { ... }`** runs code only when the test is true. **`!`** means "not". **`===`** means "exactly equal".
- **`exit;`** stops the script. **`require`** pulls in another file.

What the file does, in order

Block	What it does	Why it matters
`declare(strict_types=1)`	Makes PHP strict about types (text versus number)	Fewer surprises from wrong types
`const MAX_BODY`, **`REQUIRE_HTTPS`**	Settings at the top	Easy to change. HTTPS is switched on later (topic 5)
`ini_set('display_errors','0')`	Hides PHP error messages from the browser	No stack traces leaked (test 7)
`respond(code, body)`	Sets the status code, prints JSON, stops	One place that answers every request
`set_exception_handler(...)`	If anything crashes, send a plain 500 and log only the error type	No SQL or note text in errors or logs
Method check	Anything but POST gets 405	Test 8
Authenticate	Reads the **`Authorization: Bearer ...`** header, hashes the token with SHA-256, looks the hash up in **`api_tokens`**	Tokens are never stored. A stolen database does not give working tokens. 401 if missing, unknown, expired or revoked (tests 3 and 4)
Authorise	Token must have the **`write`** scope, otherwise 403	Test 5. Logged in is not the same as allowed
Validate	Reads at most 64 KB, decodes the JSON, checks each field is text, not empty and not too long, and that the date parses	Tests 6, 7, 9. 400 for bad input, 413 for too large
Store once	Inserts the note with a prepared statement. If **`client_id`** already exists the database refuses it and we answer 200	Test 2. Safe to repeat
Final **`respond(201,...)`**	Acknowledges a new note	Test 1

The three ideas to be able to explain

1. **Prepared statements.** The line `INSERT INTO notes (...) VALUES (?, ?, ?, ?, ?)` has `?` placeholders. The values are sent separately, so the database never treats them as SQL. That is what stops `' OR 1=1 --` (test 10) and what SQLMap will probe.
2. **Hash the token.** `hash('sha256', $token)` turns the token into a fixed fingerprint. We compare fingerprints, never tokens.
3. **Idempotent sync.** The unique `client_id` column makes the database reject a second copy, which is how a dropped mobile connection can safely retry.

Things to say if a marker asks "what would you improve?"

- Add HTTPS only (`REQUIRE_HTTPS`), then retest.
- Rate-limit requests per token, so a leaked token or a loop cannot flood the database.
- Add an audit log of who synced what, without storing note text in it.
- Encrypt `note_text` at rest, and keep the key outside the database.

Try it and break it (your findings, not mine)

- Change one thing, re-run `test_sync.sh`, and see which test fails. That shows you what each line does.
- For example, remove the `trim(...)` check and send a note of spaces only.

Sources

Checked on 10 November 2026 by web search. I read search extracts, not the full pages, so confirm on the original site before you quote anything.

- ICO: Responding to a cyber security incident (PDF), for the 72-hour reporting duty.
- Law Society: When do I have to report a data breach, for the reporting threshold and late-notice reasons.
- Camden Council: Digital social care, for the legal requirement to complete the DSPT where services are NHS-funded.
- Digital Care Hub: Who needs to complete the DSPT, for the strong recommendation to all adult social care services in England.
- National Data Guardian: The Eight Caldicott Principles (PDF).
- Microsoft Learn: Security Compliance Toolkit, for Policy Analyzer and LGPO.

Not checked against a source: Packet Tracer behaviour, such as access point VLAN support, smartphone Wi-Fi settings and SSH client commands. These come from general knowledge. Test each on your copy tonight and note what differs.